

SPOTIFY'S DATA & AI GOVERNANCE PROJECT

2.2. Organizational Roles & Responsibilities Chart

Nicolas Pichon - AIA RNCP 38777 / BC01 / Step 2.2 / v13 - 2026/10/13.

Annexes

2.2.A. Détails des rôles et responsabilités

Rôle		Rattachement	Responsabilités
Data Governance Committee	DGC	Rapporte au CDO	Piloter et arbitrer le cadre de gouvernance à l'échelle de l'entreprise [R6]
Chief Data Officer	CDO	Rapporte au CEO	Définir et faire appliquer la stratégie data [R6] [R2]
Data Protection Officer	DPO	Rapporte au CEO (GDPR, art. 38§3)	Garantir la conformité GDPR/CCPA/PCI-DSS [R6] [R2]
Data Owner	DO	Incarné par le responsable métier de chaque département	Détenir l'autorité de décision sur les actifs de données de son département
Data Steward	DS	Organisationnellement au département, fonctionnellement au CDO	Garantir la qualité et la fiabilité des données d'un domaine donné [R6]
Data Custodian	DC	Organisationnellement au HoE, transversalement l'ensemble des domaines (exécute les décisions d'accès et de sécurité de chaque DO)	Assurer la gestion technique et sécurisée du stockage des données pour l'ensemble des domaines
Model Owner	MO	Organisationnellement au PM, fonctionnellement au CDO (pour la gouvernance IA)	Être responsable d'un modèle d'IA/ML en production
Model Risk Manager	MRM	fonctionnellement principalement au CDO ; escalade directe au DGC	Contrôler les risques réglementaires et éthiques des modèles (biais, explicabilité) - fonction de contrôle indépendante des Model Owners
Legal Team	-	Rapporte au CEO	Sécuriser juridiquement les activités liées aux données [R2] ; intervient en appui du DPO sur la conformité
Head of Engineering	HoE	Incarné le DO du département Engineering	Garantir une infrastructure data conforme à la gouvernance [R2]
Marketing Director	MD	Incarné le DO du département Marketing	Garantir un usage conforme des données dans les activités marketing [R2]
Product Managers	PM	Incarnent les DOs du département Product Development	Intégrer la gouvernance dans le développement produit [R2]
Content Managers	-	Incarnent les DOs du département Content Curation	Intégrer la gouvernance dans la gestion des contenus [R2]

2.2.B. Contribution aux enjeux majeurs définis en évaluation

- **E1 (décompartmentation)** : partiellement résolu par l'introduction du *Data Owner* (autorité arbitrale par domaine) et le double rattachement des **Data Stewards** (fonctionnel CDO + organisationnel département). La structure organisationnelle pose les responsabilités nécessaires au découplage mais ne précise pas comment construire la source unique de vérité, le catalogue et la plateforme commune, qui relèvent de la mise en œuvre.
- **E2 (qualité des données)** : partiellement résolu par une chaîne de responsabilités explicite : *CDO* définit les standards de qualité, les *Data Stewards* exécutent le contrôle quotidien de la qualité par domaine, les *Data Owners* en répondent dans leur périmètre. La structure ne précise ni les règles ni l'outillage de suivi de qualité (profiling, cleansing, monitoring), qui relèvent de la mise en œuvre.
- **E3 (conformité multi-juridictionnelle)** : couvert par le tandem *DPO / Legal Team* qui réunit l'autorité de conformité et l'expertise juridique sous l'autorité exécutive. Leur proximité organisationnelle facilite la déclinaison locale des exigences GDPR/CCPA/PCI-DSS.
- **E4 (vie privée & usage éthique)** : couvert par le tandem *DPO / DGC* et un *Model Risk Manager* en appui sur le versant biais et inférence de préférences non déclarées.
- **E5 (gouvernance IA)** : partiellement résolu par la création des *Model Owners* (intégrés dans le département *Product Development*) et du *Model Risk Manager* (contrôle indépendant). La structure établit les responsabilités de gouvernance IA absentes de [D1] mais ne définit pas les procédures de détection de biais ni les seuils d'approbation, qui relèvent de la mise en œuvre.
- **E6 (montée en compétences data)** : partiellement résolu par le partage de la responsabilité data entre les métiers via les *Data Owners* et les *Data Stewards* (intégrés dans chaque département). En distribuant des rôles data nommés au sein des métiers plutôt qu'en les concentrant dans une équipe technique isolée, la structure organisationnelle diffuse la culture de gouvernance et atténue la résistance au changement. La formation, la stratégie de rétention des spécialistes et l'investissement en littérature relèvent de la mise en œuvre.

2.2.C. Matrice RACI

Activité	DGC	CDO	DPO	DO	DS	DC	MO	MRM	Legal	CEO
Stratégie & gouvernance										
Définir et approuver la politique de gouvernance data & IA	A	R	C	I	I	I	I	I	C	I
Arbitrer les conflits inter-départementaux	R	A	I	C	I	I	I	I	I	I
Piloter la montée en compétences data	A	R	I	I	C	I	I	I	I	I
Qualité & opérations data										
Définir les standards de qualité des données	A	R	I	C	C	I	I	I	I	I
Exécuter le contrôle qualité quotidien d'un domaine	I	C	I	A	R	I	I	I	I	I
Contrôler la qualité d'un jeu de données d'entraînement	I	C	I	A	R	I	C	I	I	I
Arbitrer définitions, formats et standards d'un domaine	I	C	I	RA	C	I	I	I	I	I
Gérer l'accès, le chiffrement, la sauvegarde techniques	I	C	I	A	I	R	I	I	I	I
Conformité & vie privée										
Assurer la conformité GDPR / CCPA / PCI-DSS	I	C	RA	I	I	I	I	I	C	I
Traiter les demandes d'accès / suppression des utilisateurs	I	I	RA	C	I	I	I	I	C	I
Notifier une violation de données (breach, 72h)	I	C	R	I	I	I	I	I	C	A
Garantir un usage éthique et non intrusif des données	A	C	R	C	I	I	I	C	C	I
Gouvernance IA										
Documenter le lineage des données d'entraînement	I	I	I	I	C	I	RA	C	I	I
Détecter et évaluer les biais algorithmiques	I	C	I	I	I	I	C	RA	I	I
Conseiller sur les risques légaux (data & IA)	I	C	A	I	I	I	I	C	R	I
Classifier le niveau d'impact d'un modèle	I	I	–	I	I	I	R	A	–	I
Approuver le déploiement d'une version d'un modèle à fort impact	A	C	I	I	I	I	C	R	C	I
Approuver le déploiement d'une version d'un modèle à impact modéré	I	C	I	I	I	I	R	A	I	I
Déployer une version d'un modèle à faible impact	-	I	-	I	I	I	RA	I	-	-
Contrôler les modèles à faible impact par échantillonnage	I	I	–	I	I	I	I	RA	-	-
Reclassifier le niveau d'impact d'un modèle	I	I	–	I	I	I	C	RA	–	I

Légende : R = Responsable (exécute), A = Accountable (rend compte, un seul par ligne), C = Consulted (consulté), I = Informed (informé).

Lecture de la matrice

- DGC n'est jamais *Responsable* d'une exécution opérationnelle. Il n'apparaît qu'en *Accountable* ou *Consulted* (rôle d'arbitrage transversal n'intervenant pas en production).
- DPO concentre ses *Accountable* sur les trois actions de conformité (GDPR/CCPA, droits utilisateurs, notification de violation), confirmant sa légitimité malgré son rattachement au *CEO* plutôt qu'au *CDO*.
- DGC est *Accountable* sur l'action "Approuver le déploiement d'un modèle [...]", alors que CDO, qui *préside* le DGC, n'apparaît qu'en *Consulted*. C'est la séparation recherchée pour l'indépendance du *Model Risk Manager* : elle évite que

CDO soit à la fois juge et partie sur ses propres arbitrages IA.

- Les responsabilités sur les jeux de données d'entraînement sont répartis de manière orthogonale entre *Data Steward* et *Model Owner* : *DS* reste *Responsible* de la qualité du jeu *en tant qu'actif de données* (exactitude, cohérence, fraîcheur), tandis que *MO* est *Consulted*, car il répond de l'*adéquation* de ce jeu à son modèle (représentativité, lineage, validation des ré-entraînements).
- [TODO : circuits d'approbation des modèles à impact fort/modéré/faible : voir avec [D3]]